Hardening Configuration Baseline

Ref: 5.3
Product: iConnect Plus
Organisation: Cache Digitech
Classification: Internal — Confidential
Version: 2.0
Date: 2026-11-03
Deployment model: On-premises (Cache Digitech premises) · VPN for remote access
Audience: IT infrastructure, platform engineering, security assessors

---

1. Purpose

Define the **hardening baseline** for the **internal Docker Compose server** hosting iConnect Plus: OS, PostgreSQL, reverse proxy, containers, and network exposure on Cache Digitech LAN/VPN.

---

2. Network exposure

Surface	Production target	Notes
HTTPS (nginx)	LAN + VPN clients only	Example `:8443`
PostgreSQL port	Not published to LAN — Docker internal only	Admin via SSH tunnel
Redis / RabbitMQ	Internal `erp-net` only	
MinIO API	Internal or admin-restricted	
RabbitMQ management UI	Disabled or VPN + auth	
SSH	IT bastion / restricted IP	Key-based auth

Firewall rules document: Template / Pending sign-off

---

3. Operating system (Docker host)

Control	Baseline
OS	Linux LTS — **Template / Pending sign-off** version
Patch cadence	Monthly security patches; critical within **Template / Pending sign-off**
SSH	Password auth off; fail2ban optional
sudo	Limited operators
Unused services	Disabled
Disk encryption	**Template / Pending sign-off**
NTP	See 5.2
Antivirus on host	Per IT standard — **Template / Pending sign-off**

---

4. Docker & Compose

Control	Baseline
Docker version	Pinned major — **Template / Pending sign-off**

Root in containers	Non-root user in app images where built
Privileged containers	Avoid except AV if required
Socket mount	No Docker socket in app containers
Secrets	`.env` on host — not committed
Image source	Internal registry or built on host from Git tag
Resource limits	**Template / Pending sign-off** (CPU/mem)

5. Reverse proxy (nginx)

Control	Baseline
TLS	TLS 1.2+; strong cipher suite
HSTS	Optional internal — **Template / Pending sign-off**
Security headers	`X-Content-Type-Options`, `X-Frame-Options`, etc.
Request size	Align with `API_MAX_UPLOAD_REQUEST_BYTES`
Server tokens	`server_tokens off`
Default server	Drop unknown Host

Cert files: `docker/nginx/certs/` — permissions `600` for key.

6. PostgreSQL

Control	Baseline
Version	16-alpine (inventory 1.5)
Superuser use	Migrations and break-glass only
App role	Least privilege — DML on app schemas only
`listen_addresses`	Internal Docker network
Logging	Connection failures, slow queries — **Template / Pending sign-off**
Extensions	Only approved via migration

7. Redis & RabbitMQ

Control	Redis	RabbitMQ
Password	`requirepass` target	Strong default user password
Management plugin	N/A	Restrict to VPN
TLS	Optional internal	Optional internal

8. MinIO

Control	Baseline
Root credentials	Rotated; not default `minioadmin` in prod
Bucket policy	Private; app credentials only

Public anonymous	Disabled

9. Application production flags

Variable	Production target
`ALLOW_DEMO_LOGIN`	`false`
`ENABLE_API_DOCS`	`false`
`CLAMAV_ENABLED`	`true` (target)
`REFRESH_REUSE_DETECTION`	`true`
CORS	Restrict to known internal origins

10. ClamAV

Control	Baseline
Enabled on upload path	Target production
Signature updates	Scheduled refresh of defs volume

11. Verification

Activity	Frequency	Last run
CIS-style OS checklist	Quarterly	**Template / Pending sign-off**
Docker bench security	Annual	**Template / Pending sign-off**
nginx config review	On change	**Template / Pending sign-off**

12. Related documents

Ref	Document
1.3	Application Network Diagram
1.5	Asset & Component Inventory
4.2	Cryptography & Key Management
5.6	Operations Runbook
2.3	Environment Separation

13. Change log

Date	Change	By
2026-11-03	v2.0 on-prem hardening baseline	Platform

IT + Platform joint sign-off: Template / Pending sign-off